

Data Privacy Policy

Document ID: POL-LEG-003 | Version: 5.0 | Effective: January 1, 2025 | Owner: Chief Privacy Officer

1. Purpose and Scope

Northwind Technologies collects, processes, and stores personal data in the course of its business. This policy describes how Northwind handles personal data of customers, employees, job applicants, vendors, and visitors, and the rights of those individuals with respect to their data.

This policy applies globally and is designed to meet the requirements of major data protection regimes, including the EU General Data Protection Regulation (GDPR), the California Consumer Privacy Act / California Privacy Rights Act (CCPA/CPRA), the UK Data Protection Act 2018, and similar laws in other jurisdictions.

2. Definitions

- **Personal Data:** Any information relating to an identified or identifiable individual
- **Sensitive Personal Data:** Personal data revealing racial or ethnic origin, political opinions, religious or philosophical beliefs, trade union membership, genetic data, biometric data, health data, sex life, or sexual orientation
- **Processing:** Any operation performed on personal data, including collection, recording, organization, storage, use, disclosure, or deletion
- **Data Subject:** The individual whose personal data is being processed
- **Data Controller:** The entity that determines the purposes and means of processing
- **Data Processor:** An entity that processes personal data on behalf of a controller

3. Principles

Northwind processes personal data in accordance with the following principles:

- **Lawfulness, fairness, and transparency:** data is processed lawfully and individuals are informed
- **Purpose limitation:** data is collected for specified, explicit, and legitimate purposes
- **Data minimization:** only data that is necessary for the purpose is collected
- **Accuracy:** data is kept accurate and up to date
- **Storage limitation:** data is kept only as long as necessary for the purpose
- **Integrity and confidentiality:** data is protected with appropriate security measures
- **Accountability:** Northwind can demonstrate compliance with these principles

4. Legal Bases for Processing

Northwind processes personal data only when there is a valid legal basis. The legal bases used include:

- **Consent:** The individual has given clear consent for the specific processing
- **Contract:** Processing is necessary to perform a contract with the individual
- **Legal obligation:** Processing is required by law
- **Vital interests:** Processing is necessary to protect someone's life
- **Public task:** Processing is necessary for a task in the public interest (rare for Northwind)
- **Legitimate interests:** Processing is necessary for Northwind's legitimate interests, balanced against the individual's rights

The legal basis for each processing activity is documented in Northwind's Record of Processing Activities (RoPA), maintained by the Privacy Office.

5. Data Subject Rights

Individuals have the following rights with respect to their personal data, subject to the applicable jurisdiction:

- **Right of access:** obtain confirmation of processing and a copy of their data
- **Right to rectification:** correct inaccurate or incomplete data
- **Right to erasure ("right to be forgotten"):** request deletion in certain circumstances
- **Right to restrict processing:** limit how data is used
- **Right to data portability:** receive data in a structured, machine-readable format
- **Right to object:** oppose processing based on legitimate interests or for direct marketing
- **Rights related to automated decision-making:** contest decisions made solely by automated means

Northwind responds to verified data subject requests within 30 days. Requests should be submitted to privacy@northwind.example or via the privacy portal at privacy.northwind.example.

6. International Data Transfers

Where personal data is transferred from one jurisdiction to another, Northwind uses appropriate safeguards, including:

- Standard Contractual Clauses (SCCs) approved by the European Commission
- EU-U.S. Data Privacy Framework certification (where applicable)
- UK International Data Transfer Agreement (IDTA) for transfers from the UK

- Binding Corporate Rules (in development)

A list of countries to which Northwind transfers personal data, along with the safeguards in place, is maintained in the RoPA.

7. Data Retention

Personal data is retained only as long as necessary for the purpose for which it was collected, subject to legal and regulatory requirements. General retention guidelines:

- Customer account data: duration of the relationship plus 7 years
- Marketing contact data: until consent is withdrawn or 3 years of inactivity
- Employee data: duration of employment plus 7 years (or longer where required by law)
- Job applicant data: 1 year after the application decision, unless the applicant consents to longer retention
- Vendor records: duration of the relationship plus 7 years
- Website analytics: 26 months for Google Analytics; shorter for other tools

Detailed retention schedules are maintained by the Privacy Office and reviewed annually.

8. Security

Northwind implements technical and organizational measures to protect personal data against unauthorized or unlawful processing, accidental loss, destruction, or damage. Security measures are described in detail in the Information Security Policy (POL-SEC-001). Highlights include encryption at rest and in transit, multi-factor authentication, access controls based on least privilege, vendor security reviews, and regular security testing.

9. Breach Notification

If a personal data breach occurs, Northwind follows the Security Incident Response Policy (POL-SEC-002), which includes notification to:

- EU supervisory authorities within 72 hours of awareness (GDPR Article 33)
- Affected individuals "without undue delay" when the breach is likely to result in high risk to their rights and freedoms
- Other regulators as required by applicable law

10. Privacy by Design

Northwind incorporates privacy considerations into the design of new products, services, and internal systems. Major new processing activities undergo a Data Protection Impact Assessment (DPIA) led by the Privacy Office before launch.

11. Employee Responsibilities

All Northwind employees are responsible for handling personal data in accordance with this policy. Specifically, employees must:

- Complete annual privacy training
- Limit access to personal data to what is necessary for their role
- Report any suspected privacy incidents to security-incident@northwind.example within 1 hour
- Not export, copy, or disclose personal data without appropriate authorization
- Consult the Privacy Office before launching new uses of personal data

12. Roles and Contacts

Northwind has appointed:

- **Chief Privacy Officer (CPO):** overall accountability for the privacy program
- **Data Protection Officer (DPO):** independent oversight role required under GDPR; reachable at dpo@northwind.example
- **Privacy Office:** day-to-day operational privacy team

Privacy questions and requests should be directed to privacy@northwind.example.

13. Updates to this Policy

This policy is reviewed at least annually and updated as needed to reflect changes in law, business practice, or technology. Material changes are communicated to affected individuals through appropriate channels.